



MEMORANDUM

For a Cybersecurity Posture Update

Johanna Kougbeadjo
jkougbeadjo@student.umgc.edu

TO: Chief Technology Officer, Revolut
FROM: Chief Information Security Officer, Revolut
SUBJECT: Cybersecurity Posture Update Proposal

At Revolut, we strongly value the protection of our customers' digital information. We also strive to ensure the continued stability and success of our business operations. The recent cyberattacks we faced (Page, 2022; Quinio & Venkataramakrishnan, 2023) incurred financial losses as well as damage to our reputation. This shows that there is still room for improvement in our security posture. This is why we need to take the lessons learned from these incidents to update our cybersecurity posture. Failing to do so would put us at risk of further data breaches, more financial loss, and expose us to potential regulatory repercussions (ex: GDPR-related fines).

During the past weeks, I have conducted a thorough assessment of our existing cybersecurity policies and procedures. I have also examined the various risks our company is exposed to. This allowed me to identify opportunities for improvement to strengthen our cyberdefenses.

The purpose of this memo is to present my findings and propose a cybersecurity plan. It will address three core areas of focus: the case for updating our cybersecurity measures, specific cybersecurity model attributes that apply to Revolut, and an assessment of my proposed improvements. You will find in attachment two appendixes: an overview of the different existing cybersecurity models (Appendix A), and my full custom cybersecurity plan proposal (Appendix B). The ultimate goal of these documents is to set the blueprint for an enhancement of our security posture, and ensure the confidentiality, integrity, and availability of all our digital assets.

Part One: Case for Enhanced Cybersecurity Measures

Our operational assets (financial details, proprietary data, and customer-provided information) are at risk. Given the current threat landscape, the surge in cyberattacks, and the nature of the vulnerabilities that the recent attacks we faced uncovered, it is imperative that we act now. The longer we wait to patch the holes in our defenses, the more likely we are to suffer further attacks that could cripple our company. The need for immediate action in the form of a comprehensive and robust cybersecurity plan is emphasized.

Due to the constant evolution of cyber threats, it is impossible to predict how we are going to get attacked. All we can be certain of, is that more will try to attacks us, especially as our company grows. Therefore, to protect ourselves, we need to reduce our attack surface as much as possible, address our current vulnerabilities, and make sure that we have a sturdy business continuity plan. It is also essential that we continually challenge our protective measures to keep up to date with the threat landscape and patch vulnerabilities as they are identified.

Not only such a posture will help us remain strong in the face of cyberthreats, it will also limit damages to our reputation in case of an attack and reduce the risk of regulatory repercussions.

Indeed, authorities, as well as the public, judge a company less on the fact that they got hacked than on the way they handle their security. Moreover, cyber intrusions can disrupt our operations, resulting in substantial revenue loss.

Implementing my cybersecurity plan proposal will help Revolut face these challenges and strengthen our cybersecurity.

Part Two: Applicable Security Model Attributes

My proposed information security program employs strategies taken from various cybersecurity models (see Appendix A). More precisely, it uses the Clinical Information Systems Security Model, and the Brewer-Nash model. At the heart of the security approach I recommend is the notion of regular risk assessments. Such an approach allows to identify, evaluate, and prioritize the potential threats to our assets and reevaluate our security strategy accordingly. Having a risk-centric approach is, indeed, essential to recognize and navigate all potential threats. These threats can be internal or external. They can arise from factors such as employee error, intentional undermining, hacker attacks, or competitive espionage.

Another key area of focus of my proposed security plan is an update in our security architecture. With inherent vulnerabilities in network architectures, it becomes essential to proactively implement and manage efficient security systems. These systems include intrusion detection, firewalls, and robust data encryption protocols.

Similarly, continuous monitoring of our security controls is crucial to efficiently detect potential vulnerabilities and breaches. Timely responses to these threats can prevent substantial losses and reassure our clients and stakeholders about our security infrastructure's robustness.

Disaster recovery planning is a key recommendation. By maintaining a set of procedures to restore business operations and recover critical data in case of a security incident or system failure, we can ensure business continuity in the face of adversity.

Lastly, the role of employee training and awareness can't be overstated. By conducting regular training sessions, we can equip our staff with the requisite knowledge and skills to identify and prevent cyber threats. Insightful awareness among employees forms a vital operational line of defense against potential cyber threats.

Part Three: Assessment of Proposed Implementation

The implementation of our proposed comprehensive cybersecurity plan will introduce several significant benefits to Revolut, addressing the key challenges identified earlier in this memo.

Firstly, the adoption of modern cybersecurity measures into our existing framework will noticeably decrease the number of our vulnerabilities. Indeed, keeping our cybersecurity strategy up-to-date will significantly lower the chances of successful cyberattacks. This will enhance our resilience against unexpected attacks, and decrease our response time to potential breaches.

Secondly, strictly adhering to security standards will effectively lessen the risk of regulatory penalties that could originate from non-compliance. This approach ensures that we are always in line with regulatory requirements. It will therefore mitigate any reputational damage that might occur from non-compliance. It also boosts customer trust, as we demonstrate respect for regulations and standards.

Thirdly, in the event of a breach, the execution of established disaster recovery and response plans will protect our operations. Indeed, these protocols allow us to either maintain them, or at least minimize operational downtime.

It is to be noted that as with most significant endeavors, implementing this plan comes with a cost. While this expenditure may seem steep initially, it needs to be weighed against the potential cost of a catastrophic data breach, which could far exceed the initiative's initial investment.

Moreover, the change we would be aiming for is not merely technological—it is cultural too. This initiative will entail a structured, organization-wide change management program. Training sessions to improve employee awareness about the threat landscape play a pivotal role in this program. The employees' ability to identify and respond appropriately to threats is as crucial as any technological defense we may put up.

All in all, the upfront investment and the call for a cultural shift within the organization may appear to be considerable challenges. Nevertheless, the benefits derived from the proposed measures most certainly outweigh the costs. This will significantly enhance our security posture. This will also show to our customers our commitment to their data privacy, thus cement their trust in our organization. Your approval and support in driving this transformation will be the key to its success.

Thank you,
Johanna Kougbéadjó
CISO, Revolut

Appendix A – Cybersecurity Models

The Bell-LaPadula Model

The Bell-LaPadula Model (BLP), developed in 1973 by Bell and LaPadula (1973), primarily focuses on data confidentiality. It enforces access control in government and military applications, with specific protocols for different levels of classified information. The confidentiality levels within the model are well-defined by the Simple Security Property, the Star Property, and the Strong Star Property. These properties prevent subjects from reading higher sensitivity objects and writing to those of lesser sensitivity, ensuring information's secure access across various sensitivity levels (Sandhu & Samarati, 1994). Despite its robustness in handling confidentiality, limitations persist within BLP, such as the lack of mechanisms for managing diverse data classifications. To overcome these drawbacks, updates like EO 13526, EO 13467, and DoD 5200.01-M have been formulated.

The Biba Model

Developed by Kenneth J. Biba in 1975, the Biba Security Model operates as a state-machine model, dedicated to enforcing information flow and integrity control in information systems (Biba, 1975; Kuhn, Coyne & Weil, 2010). This model upholds integrity through a hierarchical system of integrity grades. It consists of subjects (active information-processing entities) and objects (passive information repositories), designed to protect objects from unauthorized amendments by subjects. The access control policy is governed by an access tuple, encompassing a subject and an object (Hu, Ferraiolo & Kuhn, 2015). Main policy features include the simple integrity condition (stopping subjects from reading lower integrity objects), integrity star property (limiting subjects from writing to higher integrity objects), and invocation property (hiding subjects from message-passing to higher integrity objects) (Biba, 1975; McHugh, 2000).

The Clark-Wilson Model

Designed by David D. Clark and David R. Wilson in 1987, the Clark-Wilson Model is a security model that primarily addresses the flow of information and integrity goals. The model is designed to guard against unauthorized data modifications, control the activities of authorized subjects, and ensure overall consistency. It comprises a transaction structure (well-formed transaction) and an access triple (subject-program-object) that follows the principle of separation of duties (Ge, Polack & Laleau, n.d.). Certification rules (C1-C5), as defined by the model, guarantee proper data validation, transformation, adherence to separation-of-duties, and secure input data. In contrast, enforcement rules (E1-E4) ensure the maintenance of certified relationships, user authentication, and managed control over permissions. The Clark-Wilson model is applied in several contemporary database management systems (DBMS) such as Oracle, DB2, MS SQL, and MySQL (Ge, Polack & Laleau, n.d.).

The Brewer-Nash Model

The Brewer-Nash Model, often referred to as the "Chinese Wall" model, is a dynamic, state-machine model ideally suited to industries requiring the highest level of security and confidentiality (Brewer & Nash, n.d.). This innovative model was developed by David F.C. Brewer and Michael Nash as a solution to offer dynamic access permissions within the information flow model. The model functions by defining a "wall" that ensures a barrier using a ruleset, which separates and restricts subjects (users or processes) on one side from accessing or influencing objects (data or resources) on the other side (Brewer & Nash, n.d.). One of the primary goals of the Brewer-Nash model is to combat potential conflicts of interest, often prevalent in sensitive industries such as investment banking, finance, and legal sectors. These sectors often require strict control measures as they deal with highly confidential data where there is a risk of information misuse. By partitioning data access based on prior actions, the model provides a robust mechanism to maintain data confidentiality and safeguard against unethical practices (Kessler, 1992). Crucially, the Brewer-Nash model is noted for its "sanitization" procedure, where selective data available to subjects becomes 'cleansed' upon certain conditions. This characteristic makes the model unique in its approach to maintaining confidentiality and integrity.

All in all, the Brewer-Nash and its "Chinese Wall" model offer a nuanced, dynamic approach to data integrity and confidentiality that is utilized by industries requiring stringent information security controls (Loock, Marianne & Eloff, 2005).

The Clinical Information Security Model

The Clinical Information Systems Security Model, developed by R.J. Anderson in 1996, was designed to balance the security of patient records with efficient information sharing among medical practitioners (Anderson, 1996). The model's nine principles effectively address various risks concerning confidentiality, integrity, informed consent, accountability, and data aggregation concerns (Anderson, 2008). Access to records is managed through several approaches, including Access Control List (ACL), domain control, or encryption key management. Confidentiality is maintained by restricting access only to users listed on the ACL and implementing the Bell-LaPadula policy. Informed consent is achieved through authorization of ACL subjects, while accountability requires maintaining logs for all accesses to records and tracking changes to ACLs. Deductibility prevention involves measures such as patient notifications and data anonymization to minimize chances of deduction.

To sum up, the Clinical Information Systems Security Model offers a comprehensive framework for tackling various security concerns that arise in maintaining secure patient records in the healthcare industry. By prioritizing aspects like confidentiality, integrity, and consent, it allows for efficient and secure exchange of sensitive information among medical practitioners.

The Noninterference Model

The Noninterference Model, also known as the Goguen-Meseguer security model, was introduced by J.A. Goguen and J. Meseguer in 1982. Based on the information flow model, this

model focuses on the impact of higher-sensitivity actions on lower-level interactions, aiming to prevent interference and potential contamination across different compartments (Goguen & Meseguer, 1982; Goguen & Meseguer, 1984). This model is highly relevant for sectors that deal with multilevel security, discretionary access, compartmentation, and automatic distribution. It is designed to address covert channels and inference attacks. Information flow is regulated through non-interference assertions that define the capabilities of subjects (Millen, 1999). For example, consider four compartmentalized subjects: A, B, C, and D. Non-interference assertions A1, A2, and A3 delineate their capabilities. Unlike the Bell-LaPadula (BLP) model, which focuses on object-based information flow, the Noninterference Model concentrates primarily on subjects.

In summary, the Noninterference Model provides a thorough approach to handling security concerns, particularly when preventing interference between subjects and compartments is a top priority. By closely examining subject-based information flows, the model is effective in addressing various security threats.

The Deductibility Model

The Deducibility Model is a security model predominantly associated with data security, particularly aimed at reducing the risk of users inferring or deducing sensitive information beyond their allocated access privileges. This model, as discussed by M. Bishop in 2009, has its conceptual roots in effective access control mechanisms and elaborates on the benefits of minimizing deducibility via proactive data aggregation. This model caters especially to sectors dealing with sensitivity-tiered data. It prevents users with low security-level access from being able to deduce individually stored data at a higher security level (Jajodia & Sandhu, 1991). Therefore, the Deducibility Model serves as a vital tool in enhancing the security of aggregated data, as it contributes significantly to ensuring the highest standards of data confidentiality, integrity, and availability. It plays a crucial role in maintaining a robust defense against unauthorized access and potential misuse of sensitive data, emphasizing strict and effective access control measures to ensure non-deducibility of information (Hu, Kuhn, Ferraiolo, Voas & Scarfone, 2013).

The Graham-Denning Model

The Graham-Denning model, developed by G.S. Graham and P.J. Denning in 1972, is an information access model that focuses on managing the relationship between subjects, objects, and rights (Graham & Denning, 1972). The model was designed specifically for systems that require well-defined access controls and precise management of permissions (Sandhu, Coyne, Feinstein & Youman, 1996). In the Graham-Denning model, protection levels span a continuum from no sharing to sharing of 'certified' subsystems (Sandhu, Samarati & Subrahmanian, 1997). The model also defines secure operations for creating, deleting, and providing access to an object or subject. These operations aim to securely manage user actions such as read, grant, delete, and transfer access rights (Harrison, Ruzzo & Ullman, 1976). This model holds particular significance in sectors that require meticulous control over information access, such as technology and digital industries with intricate information systems (Lampson, 1971). By clearly defining access rights, the Graham-Denning model ensures that sensitive data remains protected and information systems remain secure.

Appendix B - Cybersecurity Plan for Revolut

Cybersecurity refers to the defense of information technology (IT) systems, networks, and data from various cyber threats. These threats often aim to access, change, or even destroy sensitive information, extort money from users, or disrupt normal business operations. This often leads to harm or financial losses (Kaspersky, n.d.). In order to protect their assets, organizations and individuals must be vigilant and implement cybersecurity measures proactively. These measures are typically designed based on certain principles, such as preventing unauthorized access, maintaining the integrity of the data, and ensuring the availability of services when needed (Stallings, 2012).

The role of cybersecurity is to protect the confidentiality, integrity and availability of data. These three core principles are called the CIA Triad. The principle of Confidentiality aims at preventing the disclosure of information to unauthorized individuals or systems. Encryption is often used to maintain confidentiality (Stallings, 2012). The role of Integrity is to guarantee the accuracy and consistency of data during its entire life-cycle. This involves the mechanisms to prevent unauthorized access or alteration of data (Stallings, 2012). Availability, on the other hand, ensures timely and reliable access to data and resources to authorized individuals (Stallings, 2012).

This cybersecurity plan is designed to protect its digital information, infrastructure, and customer data from threats. This plan doesn't just conform to Revolut's IT vision, mission, and goals; it is rooted in a deep understanding of its unique risk landscape and stands to ensure its most important asset, trust.

Information Security Program

Enterprise cybersecurity focuses on protecting businesses' information assets. It does so by crafting a solid defense strategy that is grounded in the CIA triad.

Constructing a robust cybersecurity framework requires an enterprise-wide policy. That policy should establish clearly defined directives and views from organizational leadership on data protection and cybersecurity. It should also determine the allocation of roles and responsibilities to all levels, from top management to employees, for maintaining adherence to the cybersecurity policy (Stallings, 2012).

Our proposed information security program exploits a range of strategies drawn from various security models like the Clinical Information Systems Security Model, Brewer-Nash model, and Access Control Systems.

- **Risk Assessment:** Regular risk assessment to identify, evaluate, and prioritize potential threats to information assets forms the pillar of our security strategy. Recognizing both internal and external threats, from employee error or purposeful undermining to hacker attacks or competitive espionage, is vital in crafting a resilient defense.

- **Security Architecture:** Given the vulnerabilities inherent in network architecture, proactive measures to implement and manage effective security systems that include intrusion detection, firewalls, and robust data encryption protocols are required (Anderson, 2008; Hu, Ferraiolo, & Kuhn, 2015).
- **Continuous Monitoring:** Continuous observation of the organization's security controls is necessary to detect potential vulnerabilities and breaches efficiently. Timely response to these threats can prevent significant losses and maintain the trust of clients and stakeholders in our security infrastructure (McHugh, 2000).
- **Disaster Recovery Planning:** We recommend maintaining a set of procedures to restore business operations and recover critical data if a security incident or system failure occurs. Having a recovery plan not only minimizes potential damage but also ensures business continuity in the face of adversity (Richardson, 2020).
- **Employee Training and Awareness:** Regular training sessions will impart knowledge and skills to all staff to identify and prevent cyber threats. Creating awareness and responsibility among employees is as crucial as bolstering our technological defense against potential threats (Richardson, 2020).

Risk Management

Revolut is facing two types of threats: internal threats and external threats. The nature of insider threats can vary broadly-some arise from employee negligence, others from unknowing employees facilitating attacks unknowingly (for example, falling victim to phishing scams), disgruntled employees, and potential risks posed by business suppliers or contractors. Outsider threats, on the other hand, can range from cybercriminals who perform cyberattacks to steal money or customer data, to competitors engaging in cyber espionage. These threats incur various risks for the company as they can inflict damage to the well-being of the company.

The following table outlines the main risks faced by Revolut.

Risk Type	Level of Damage (1 <-> 4)	Likelihood (1 <-> 4)	Level of Risk (1 <-> 4)
Reputational damage due to attack	4	4	4
Loss of revenue due to attack	4	4	4
Regulatory sanctions due to non-compliance or negligence	4	1	2.5
Business operation halted because of attack	4	2	3

Data misuse or mishandling by employees could escalate into a cybersecurity crisis	3	4	3.5
Software vulnerability exposing data	3	4	3.5

To manage these risks, we propose a comprehensive plan that factors in the probabilities, potential impact, and relevance to business operations. Our intention is to maintain a proactive stance in identifying and mitigating risks well before they materialize (Scarfone, 2007).

Regular audits and vulnerability assessments will be part of this process. These procedures ensure a continuous check on the system's health, vital to identifying vulnerabilities and gaining insights into possible intrusion points.

Security Mitigation Strategies

A sound security strategy doesn't uniquely rest on technological solutions. It should also include the human factor. Drawing from this understanding, I propose a five-tiered approach to build a resilient and thorough security framework for Revolut. This strategy is composed of:

- **Regular Updates and Patches:** We will acquire software updates and patches from the manufacturer or vendor. These will be applied monthly or in accordance with the vendor's recommendation. The IT department will be responsible for delivering and applying the patches, using tools such as SCCM.
- **Strengthening Network Security:** We will establish more stringent access management by implementing Multi-Factor Authentication (MFA) methods such as tokens, biometrics, or smartphone authentication apps.
- **Creating a Culture of Security:** We will develop in-house cybersecurity training materials and designating existing qualified staff or hiring additional personnel for this function.
- **Strong Incident Response Plan:** We will draft a comprehensive incident response plan. It will include a clear chain of command and responsibilities. It will also require coordination with external cybersecurity experts if necessary.
- **Reviewing Security Protocols of Suppliers and Contractors:** We will require partners, suppliers, and contractors to meet a minimum of Cybersecurity Maturity Model Certification Level 2 or an equivalent NIST standard. We will offer assistance and guidance to suppliers in achieving compliance to help small businesses.

The aim of these mitigation strategies is to shift the paradigm from 'react and repair' to 'predict and prevent'. Adopting such a proactive approach, that considers both technical and human elements, will ensure a resilient, fortified defense against ever-evolving cyber threats.

Security Priorities

Having a clear idea of what our priorities are in terms of cybersecurity is essential to the decision-making process. These priorities form the cornerstone of our security policy and should be taken into account in every decision that impacts the cybersecurity of the company.

1. **Data Confidentiality:** Proactively protecting confidential business and customer data.
2. **System Availability:** Ensuring robust, secure, and reliable access to Revolut services.
3. **Data Integrity:** Preserving the credibility and accuracy of stored and transmitted information.
4. **Controlled Access:** Strict access controls to ensure data is accessed by authorized personnel while maintaining proper access logs.
5. **Transparency & Oversight:** Transparency in security practices and robust audit controls to allow thorough oversight.

In conclusion, my cybersecurity plan for Revolut is based on the core principles of the CIA Triad. It has been developed to improve the protection of our infrastructure against a wide range of internal and external risks. The approach I recommend involves risk management, strategic security measures, and clear priorities. It is aimed at establishing adaptable defenses. To effectively address the changing landscape of cybersecurity threats, I strongly recommend adopting the proposed plan. It will help foster a culture of security awareness throughout all levels of the organization. It will also commit us to regular reviews and updates of our measures to enhance our cybersecurity posture.

References

- Graham, G. S., & Denning, P.J. (1972). Protection—principles and practice. AFIPS Conference. <https://dl.acm.org/doi/pdf/10.1145/1478873.1478928>
- Sandhu, R., Coyne, E., Feinstein, H., & Youman, C. (1996). Role-Based Access Control Models. IEEE Computer, 29(2), 38-47. <https://csrc.nist.gov/CSRC/media/Projects/Role-Based-Access-Control/documents/sandhu96.pdf>
- Jajodia, S., Samarati, P., & Subrahmanian, V. S. (1997). A Logical Language for Expressing Authorisations. In Proceedings of the Sixth IEEE Computer Security Foundations Workshop.
- Harrison, M. A., Ruzzo, W., & Ullman, J. (1976). Protection in Operating Systems. Communications of the ACM, 19(8), 461-471. <https://dl.acm.org/doi/pdf/10.1145/360303.360333>
- Lampson, B. W. (1971). Protection. In ACM SIGOPS Operating Systems Review (Vol. 5, No. 1, pp. 18-24). ACM. <https://citeseerx.ist.psu.edu/document?repid=rep1&type=pdf&doi=4b6dde3ec9d36f3c7f203dbe592862e15758ad50>
- Jajodia, S., & Sandhu, R. (1991). Towards a multilevel secure relational data model. ACM SIGMOD Record, 20(2), 50-59. <http://csm.beirut.lau.edu.lb/~rharaty/pdf/2005%20-%204.pdf>
- Hu, V. C., Kuhn, R., Ferraiolo, D., Voas, J., & Scarfone, K. (2013). Policy machine: A novel architecture and framework for access control policy specification and enforcement. Journal of Information Security and Applications, 18(1), 3-19. https://csrc.nist.gov/pm/documents/journal-of-sys_and_arch.pdf
- Goguen, J. A., & Meseguer, J. (1982). Security Policies and Security Models. In 1982 IEEE Symposium on Security and Privacy (pp. 11-20). IEEE.
- Goguen, J. A., & Meseguer, J. (1984). Unwinding and Inference Control. In Proceedings of the 1984 IEEE Symposium on Security and Privacy. IEEE.
- Millen, J. (1999). 20 years of covert channel modeling and analysis. In Proceedings of the 22nd National Information Systems Security Conference. NIST. <http://jonmillen.com/pubs/20yrcc.pdf>
- Anderson, R. J. (1996.) Security in clinical information systems. Cambridge, England: University of Cambridge Computer Laboratory. <https://www.cl.cam.ac.uk/~rja14/Papers/policy11.pdf>
- Anderson, R. (2008). Security Engineering: A Guide to Building Dependable Distributed Systems (2nd ed.). Wiley.

Brewer, D. F. C., & Nash, M. (n.d.). The Chinese wall security policy. Gama Secure Systems, UK. https://www.cs.purdue.edu/homes/ninghui/readings/AccessControl/brewer_nash_89.pdf

Kessler, V. (1992). On the Chinese Wall model. In: Deswarte, Y., Eizenberg, G., Quisquater, JJ. (eds) Computer Security — ESORICS 92. ESORICS 1992. Lecture Notes in Computer Science, vol 648. Springer, Berlin, Heidelberg. <https://link.springer.com/content/pdf/10.1007/BFb0013891.pdf?pdf=inline%20link>

Loock, Marianne & Eloff, Jan. (2005). A new Access Control model based on the Chinese Wall Security Policy Model.. 1-10. https://www.researchgate.net/publication/220803268_A_new_Access_Control_model_based_on_the_Chinese_Wall_Security_Policy_Model

Ge, X., Polack, F., & Laleau, R. (n.d.). Secure database development and the Clark-Wilson security model. University of York, UK.

Biba, K. (1975). Integrity considerations for secure computing systems. MTR-3153. <http://seclab.cs.ucdavis.edu/projects/history/papers/biba75.pdf>

Hu, V.C., Ferraiolo, D.F., & Kuhn, D.R. (2015). Assessment of Access Control Systems. National Institute of Standards and Technology, Computer Security Division, Information Technology Laboratory. <https://nvlpubs.nist.gov/nistpubs/legacy/ir/nistir7316.pdf>

Kuhn, D.R., Coyne, E.J., & Weil, T.R. (2010). Adding Attributes to Role-Based Access Control. IEEE Computer, 43(6), 79-81. <https://csrc.nist.gov/files/pubs/journal/2010/06/adding-attributes-to-rolebased-access-control/final/docs/kuhn-coyne-weil-10.pdf>

McHugh, J., (2000). Testing Intrusion detection systems: a critique of the 1998 and 1999 DARPA Intrusion Detection System Evaluations as performed by Lincoln Laboratory. ACM Transactions on Information and System Security, 3(4), 262-294. <https://dl.acm.org/doi/pdf/10.1145/382912.382923>

Sandhu, R.S., & Samarati, P. (1994). Access Control: Principles and Practice. IEEE Communications Magazine, 32(9), 40-48. <https://citeseerx.ist.psu.edu/viewdoc/download;jsessionid=6D51DD2B4758DCAD461316E26A1A2B8F?doi=10.1.1.30.5029&rep=rep1&type=pdf>

Anderson, R. J. (1996.) Security in clinical information systems. Cambridge, England: University of Cambridge Computer Laboratory. <https://www.cl.cam.ac.uk/~rja14/Papers/policy11.pdf>

Anderson, R. (2008). Security Engineering: A Guide to Building Dependable Distributed Systems (2nd ed.). Wiley.

Hu, V.C., Ferraiolo, D.F., & Kuhn, D.R. (2015). Assessment of Access Control Systems. National Institute of Standards and Technology, Computer Security Division, Information Technology Laboratory. <https://nvlpubs.nist.gov/nistpubs/legacy/ir/nistir7316.pdf>

McHugh, J., (2000). Testing Intrusion detection systems: a critique of the 1998 and 1999 DARPA Intrusion Detection System Evaluations as performed by Lincoln Laboratory. *ACM Transactions on Information and System Security*, 3(4), 262-294.
<https://dl.acm.org/doi/pdf/10.1145/382912.382923>

Richardson, M. D., Lemoine, P. A., Stephens, W. E., & Waller, R. E. (2020). Planning for Cyber Security in Schools: The Human Factor. *Educational Planning*, 27(2), 23-39.
<https://files.eric.ed.gov/fulltext/EJ1252710.pdf>

Scarfone, K., and Mell, P. (2007). "Guide to Intrusion Detection and Prevention Systems (IDPS)." Computer Security Resource Center, National Institute of Standards and Technology (NIST). <https://nvlpubs.nist.gov/nistpubs/legacy/sp/nistspecialpublication800-94.pdf>

Kaspersky. "What is Cybersecurity?" n.d., <https://www.kaspersky.com/resource-center/definitions/what-is-cyber-security>.

Stallings, W., & Brown, L. (2012). *Computer Security: Principles and Practice*. Prentice Hall.

Page, C. (2022, September 22). *Revolut confirms cyberattack exposed personal data of tens of thousands of users*. TechCrunch. <https://techcrunch.com/2022/09/20/revolut-cyberattack-thousands-exposed/>

Quinio, A., & Venkataramakrishnan, S. (2023, July 9). *Revolut's US payment flaws allowed thieves to steal \$20mn*. Financial Times. <https://www.ft.com/content/0025347f-6e0c-4dbd-9762-e4eec0431050>